Proposal Solusi — Nusantara Shield v5.4.1

Posko Pertahanan Siber Luring: Peringatan Dini, Isolasi Cepat, dan Rantai Bukti Forensik

Kompetisi	Kartika Cyber Hackathon 2026 · Pusat Siber Angkatan Darat (Pussiberad) × CODEPOLITAN
Kategori	02 · **Penangkalan (*Defensive Shield*)** — *Threat Intelligence Platform* dan *Automated Incident Response*
Tim	Muhammad Isa Ananta · Hasan Basri · Melia Fajar Hasanah
Status purwarupa	**Berfungsi penuh** · 425 uji otomatis lulus · AI deteksi anomali dan aturan deteksi berjalan lokal · luring tanpa internet
Tanggal	27 Oktober 2026

1. Ringkasan Eksekutif

> **Nusantara Shield: perisai pertahanan (*Defensive Shield*) luring yang mendeteksi, mencegah, dan membantu merespons serangan siber: memperingatkan lebih dulu, memutus dalam 1,2 detik, dan tidak pernah menghapus barang bukti.**
>
> **Serangan siber tidak menunggu rapat staf.** *Ransomware* mengenkripsi satu *server* per menit, sementara posko siber masih memilah ratusan peringatan, menunggu izin berjenjang, dan menyusun laporan dengan tangan. Saat jaringan akhirnya diputus atau dipulihkan, jejak penyerang sering sudah terhapus.

Nusantara Shield adalah perisai pertahanan siber (kategori **Penangkalan, *Defensive Shield***) dan **sistem pendukung keputusan (SPK)** bagi posko satuan, ibarat **Perwira Staf Siber Digital**. Ia bekerja dengan tiga kata kerja: **mendeteksi** ancaman (aturan deteksi, AI lokal, dan kabar ancaman), **mencegah** aset berisiko diserang (WASPADA dan Perketat), dan **membantu merespons** dengan urutan baku yang berjalan otomatis setelah satu keputusan Operator. Ia menjaga **jaringan perkantoran (IT)** dan **sistem kendali fasilitas (OT)** dalam satu layar. Ia mengamati tanpa henti, mencocokkan setiap kabar ancaman dengan aset milik satuan sendiri, dan menyajikan langkah penindakan yang sudah dibakukan dalam doktrin. **Keputusan tetap di tangan manusia.** Begitu Operator menahan tombol, sistem menjalankan urutan baku secara otomatis (di purwarupa, perintah ke perangkat jaringan masih simulasi):

Nusantara Shield bekerja dalam **dua lapis**:

1. **Lapis pertama: deteksi dan tangkal lebih dulu.** Kabar ancaman (CTI), AI lokal, dan aturan deteksi (*login* gagal berulang, pemindaian *port*) menaikkan aset IT maupun OT yang berisiko ke **WASPADA** sebelum diserang. Satu klik **Perketat** menurunkan paparannya. Contoh terukur: kabar celah Modbus menaikkan pengendali genset ke peluang ≈66%, dan Perketat menurunkannya ke ≈20%.
2. **Lapis kedua: bila ancaman tetap tembus, bukti dulu, baru putus.** Begitu Operator memutuskan, *server* menjalankan alur baku di bawah dalam urutan yang tidak bisa dilompati.

> **Dua kunci konfirmasi sebelum jaringan diputus.** Kunci pertama dipegang mesin: kabar ancaman (CTI) dicocokkan dengan aset satuan, AI lokal menilai lalu lintasnya, dan aturan deteksi menghitung peristiwa *login* serta koneksi masuk, tetapi hasilnya hanya menaikkan status ke WASPADA. Kunci kedua dipegang manusia: hanya akun Operator yang dapat memerintahkan isolasi, dengan menahan tombol 0,6 detik; permintaan dari akun Pengamat ditolak *server*. **Tidak ada satu sinyal pun yang memutus jaringan vital secara otomatis penuh (*autonomous*) tanpa keputusan akhir manusia.**



Alur baku Nusantara Shield. Begitu Operator memutuskan, server menjalankan empat langkah ini dalam urutan yang tidak bisa dilompati.

Setiap langkah tercatat permanen dalam buku berantai Hash-based Message Authentication Code (HMAC) yang tidak bisa diubah diam-diam.

Hasilnya, postur pertahanan bergeser dari reaktif menjadi proaktif.

- **Ancaman terlihat lebih awal.** Aset berisiko dinaikkan ke status *waspada* sebelum diserang, baik karena kabar ancaman (CTI), karena **AI lokal** menilai lalu lintasnya tidak wajar, maupun karena **aturan deteksi** melihat *login* gagal berulang atau pemindaian *port*.
- **Penahanan berlangsung dalam hitungan detik**, bukan jam.
- **Tidak ada pemulihan yang menghapus barang bukti.** Pemulihan dikunci sampai sidik jari bukti dicocokkan ulang.

Indikator (terukur pada purwarupa)	Hasil
Peringatan dini: peluang serangan genset setelah kabar celah Modbus, sebelum dan sesudah Perketat (belum ada serangan)	**≈66% → ≈20%**
Waktu dari keputusan Operator sampai jalur pertama terputus, bukti sudah aman	**≈1,2 detik**
Deteksi *login* gagal berulang dari satu alamat (ambang terbuka di kode, dikunci uji)	**8 kali dalam 60 detik**
Beban Central Processing Unit (CPU) *server* untuk **300 layar** pemantau serentak, versi akhir	**≈1,5%** siaga · **≈1,7%** saat serangan
Lalu lintas jaringan ke 300 layar saat serangan intensif, berkat siaran ralat (uji beban 17 Okt 2026)	**−80%** (8,4 → 1,7 MB/s)
Waktu AI lokal menilai lalu lintas 9 aset (*Isolation Forest*, tanpa internet)	**≈10 milidetik**
Perilaku sistem yang dikunci uji otomatis	**425 uji**

Angka CPU diukur ulang 26 Okt 2026 dengan tools/ukur_beban.py (Linux 2 inti, 300 siaran SSE sungguhan). Angka 2,8% pada versi dokumen sebelumnya diukur dengan alat dan mesin lain, sehingga tidak dibandingkan langsung. Asal setiap angka dan pemetaan ke lima kriteria penilaian ada di §7.

> **Banyak sistem pertahanan berhenti di alarm.** Nusantara Shield berlanjut sampai bukti tersegel, jalur terputus, dan LAPSIT terbit, dalam satu alur yang dikunci *server* setelah satu keputusan Operator, dan semuanya berjalan tanpa internet.

---

2. Latar Belakang, Urgensi, dan Pernyataan Masalah

2.1 Fakta Sejarah: Dua Kegagalan yang Sudah Terjadi

Kejadian	Yang terjadi	Tahap Observe–Orient–Decide–Act (OODA) yang tertinggal
***Ransomware* Brain Cipher di Pusat Data Nasional Sementara (PDNS) Surabaya, Juni 2024**	Menurut BSSN, upaya mematikan Windows Defender terekam **17 Juni 2024 pukul 23.15 WIB**, sedangkan aktivitas jahat baru berjalan **20 Juni pukul 00.54** dan Defender *crash* semenit kemudian. Ada **≈49 jam** tanda bahaya yang tidak berbuah tindakan, dan hanya **≈2% data** punya cadangan. Layanan imigrasi lumpuh, layanan banyak instansi pusat dan daerah terganggu berhari-hari, dan pelaku meminta tebusan USD 8 juta.	**Amati dan Orientasi:** tanda bahaya ada, tetapi tidak dikenali dan tidak diputuskan tepat waktu
Dugaan *ransomware* LockBit 3.0 di Bank Syariah Indonesia (BSI), Mei 2023	Layanan ATM dan *mobile banking* terganggu **8–11 Mei**. Analis menduga penyusupan dimulai sejak **libur Lebaran**, dan pelaku mengklaim mencuri **1,5 TB data**. Saat layanan dipulihkan, hasil investigasi forensik resmi masih ditunggu.	**Amati** terlambat; **Bertindak** harus memilih antara memulihkan layanan secepatnya atau menjaga jejak forensik





Ilustrasi dua insiden, diolah dari detikINET dan CNBC Indonesia (PDNS) serta Bisnis.com/CISSReC (BSI). Klaim pencurian 1,5 TB adalah klaim pelaku dan belum terverifikasi.

Akar masalahnya sama: siklus OODA yang lambat dan tidak adanya prosedur berdoktrin yang dijalankan mesin. Penyusup sempat berdiam berhari-hari. Ketika layanan vital lumpuh, keputusan dan pemulihan dikejar waktu, sementara rantai barang bukti belum diamankan.

2.2 Proyeksi Ancaman: Fasilitas Kesehatan Satuan

> **Bayangkan jika kelumpuhan seperti PDNS terjadi pada infrastruktur kesehatan satuan, seperti RSPAD Gatot Soebroto atau rumah sakit jajaran Kesdam.** Serangan siber mendadak tidak hanya mengunci **rekam medis dan layanan klinis (IT)**, tetapi berpotensi mengambil alih **sistem kendali fasilitas (OT)** seperti genset dan kelistrikan ruang operasi. Di fasilitas kesehatan, lambat merespons insiden bukan sekadar soal data hilang, tetapi soal **nyawa dan keamanan nasional**.

Proyeksi ini berpijak pada dua kejadian nyata:

- **Data kesehatan Indonesia bernilai tinggi bagi penyerang.** Pada Mei 2021, **279 juta data** penduduk dijual di forum peretas. Sampel yang diperiksa Kominfo diduga kuat berasal dari BPJS Kesehatan.
- ***Ransomware* sudah menyasar Operational Technology (OT) rumah sakit.** Pada **Agustus 2026**, Health Sciences Centre di Winnipeg, Kanada, melaporkan *ransomware* yang mengenai sistem pemeliharaan fasilitas, termasuk **pendingin udara (HVAC) dan kendali akses pintu**. Pelayanan pasien tetap berjalan, karena jaringan klinis dan jaringan fasilitas terpisah.

Rumah sakit adalah arena tempat konvergensi Information Technology (IT) dan OT paling nyata. Pelajarannya: zona IT dan OT harus terpisah, ancaman OT harus dikenali lebih awal, dan jalur penyerang harus diputus dalam hitungan detik, tanpa menghapus bukti.

2.3 Jawaban Nusantara Shield

- **Deteksi dari peristiwa mentah.** Aturan deteksi di *server* menghitung peristiwa *login* dan koneksi masuk: **8 *login* gagal dari satu alamat dalam 60 detik**, *login* berhasil sesudah rentetan itu, atau **15 kombinasi aset:*port* berbeda dalam 10 detik** (pemindaian *port*). Ambangnya tertulis terbuka di kode dan dikunci uji. Hasilnya hanya menaikkan aset ke WASPADA.
- **Amati lebih awal, IT maupun OT.** Kabar ancaman dikorelasikan dengan inventaris aset. Kabar celah protokol industri Modbus langsung menaikkan **pengendali genset** ke WASPADA (≈66%) sebelum ada serangan, dan satu klik **Perketat** menurunkannya. **AI lokal** (*Isolation Forest*) juga menilai lalu lintas tiap aset; lalu lintas Modbus tak wajar menaikkan genset ke WASPADA **tanpa menunggu kabar ancaman**, lengkap dengan alasannya.
- **Bukti dulu, baru putus: IT dan OT.** Bukti disegel dengan sidik jari Secure Hash Algorithm 256-bit (SHA-256), lalu **≈1,2 detik** kemudian aset IT diisolasi. Untuk OT, perintah ke sakelar terkelola memutus **jalur kantor → zona kendali**, sehingga peretasan tidak menjalar ke infrastruktur fisik. Genset **tidak dimatikan**, tetapi beralih ke kendali lokal (NIST SP 800-82). Pemutusan tanpa bukti ditolak *server*.
- **Pemulihan tidak menghapus jejak.** Tombol Pulihkan terkunci sampai sidik jari SHA-256 bukti **dicocokkan ulang**.
- **Tidak menggantungkan pertahanan pada pusat data di luar kendali satuan.** Saat PDNS lumpuh, layanan banyak instansi yang dititipkan di sana ikut berhenti, dan hanya sekitar 2% data yang punya cadangan. Pelajarannya: inti pertahanan satuan (deteksi, keputusan isolasi, bukti, dan laporan) harus tetap berjalan di *server* posko sendiri, tanpa awan dan tanpa internet (lihat 5.1).
- **Batas yang jujur:** di purwarupa, rumah sakit dan genset adalah data contoh, dan perintah ke sakelar masih berupa **simulasi webhook**. Sensor protokol industri dan sambungan ke sakelar fisik adalah peta jalan.

Sumber: detikINET (PDNS) · detikINET, kronologi BSSN (26 Juni 2024) · ANTARA, Raker Komisi I DPR (27 Juni 2024) · CNBC Indonesia (cadangan 2%) · Bisnis (pemulihan BSI) · Bisnis (kronologi BSI) · CNN Indonesia (279 juta data) · Nozomi Networks (Winnipeg HSC)

2.4 Empat Kelemahan Pola Respons Manual

Empat kelemahan berikut lazim ditemui pada pola respons insiden manual:

#	Masalah	Gejala di lapangan	Akibat bagi satuan
1	**Banjir peringatan** (*alert fatigue*)	Ratusan peringatan per hari, sebagian besar tidak menyangkut aset satuan	Ancaman nyata tenggelam; Operator lelah dan terlambat bereaksi
2	**Penahanan (*containment*) yang lambat dan ragu**	Izin berjenjang, tombol bermakna ganda, laporan disusun manual di tengah krisis	Penyerang leluasa menyebar selama keputusan tertunda
3	**Rusaknya bukti forensik saat pemulihan darurat**	*Server* di-*restart* atau dipulihkan dari cadangan sebelum bukti disalin	Pelaku tidak bisa diidentifikasi; rantai barang bukti (*chain of custody*) tidak dapat dipertanggungjawabkan
4	**Petugas jaga bukan ahli siber, dan jarang berlatih**	Ahli siber di satuan hanya satu atau dua orang; latihan tanggap insiden jarang, mahal, dan tidak dinilai	Saat insiden datang, urutan tindakan dipelajari di tengah krisis

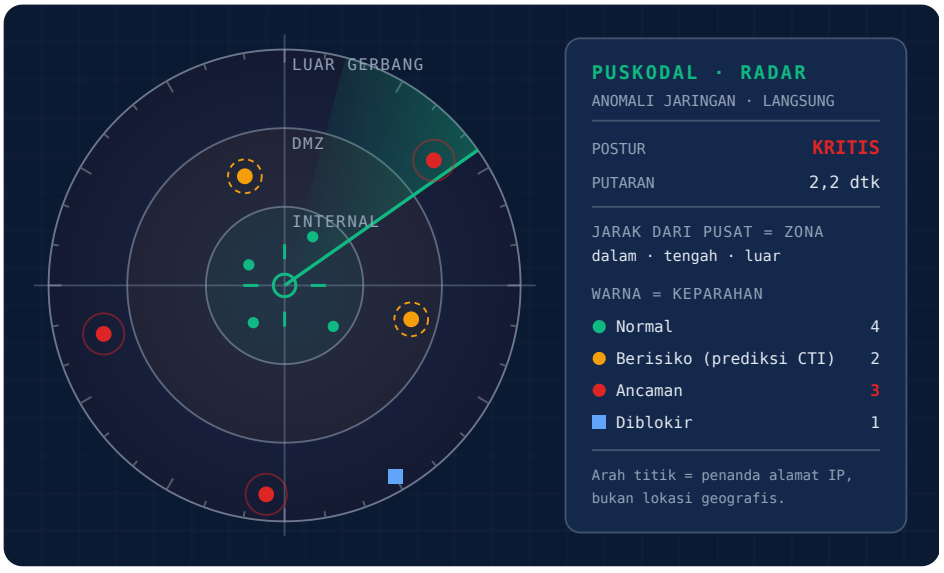
Kelemahan keempat muncul dari dua sumber. Diskusi komunitas peserta (November 2026), yang merujuk visi-misi Satuan Siber (Satsiber) TNI dan layanan Tim Tanggap Insiden Siber (TTIS) TNI AD, menyebut masalah terbesar di lingkungan TNI: *ransomware* dan *phishing*, sistem lama yang sulit diperbarui, dan **kurangnya SDM siber spesialis**. Misi Satsiber TNI sendiri memuat pembentukan prajurit siber dan sosialisasi keamanan informasi kepada personel. Webinar pembekalan Kartika Cyber Hackathon 2026 menyebut hal yang sama dan menunjuk latihan (*cyber drill*) sebagai cara membangun kesiapan yang terukur.

> **Inti persoalannya:** kecepatan dan ketertiban forensik selama ini dianggap saling bertentangan. Nusantara Shield membuktikan keduanya bisa dicapai sekaligus.

---

3. Solusi yang Ditawarkan

3.1 Cara Kerja dalam Siklus OODA



Ilustrasi konsep Radar Anomali pada tahap Amati: jarak dari pusat menunjukkan zona jaringan, warna menunjukkan tingkat keparahan.

Tahap OODA	Pertanyaan komandan	Jawaban Nusantara Shield (sudah berjalan)
Amati (*Observe*)	Apa yang terjadi di jaringan?	Aset **IT dan OT**, **Radio Cyber Threat Intelligence (CTI)/OSINT**, Radar Anomali, dan Peta Ancaman Global dalam satu layar
Orientasi (*Orient*)	Apakah ini menyangkut aset kita?	**Korelasi otomatis** antara kabar ancaman dan inventaris aset, ditambah **skor anomali AI lokal** atas lalu lintas tiap aset, menghasilkan **peluang serangan per aset** (*risk-based scoring*): $1 - (1 - p_{CTI})(1 - p_{AI})$. Peluang ≥50% menaikkan aset ke **WASPADA** sebelum diserang.
Putuskan (*Decide*)	Tindakan apa yang diizinkan?	*Playbook* **praotorisasi** (*pre-authorized*). Operator cukup **menahan tombol 0,6 detik**, sehingga tidak ada klik panik.
Bertindak (*Act*)	Bagaimana mengeksekusi tanpa merusak bukti?	Urutan terkunci di *server*: **amankan bukti (SHA-256) → isolasi → Laporan Situasi (LAPSIT) otomatis → pemulihan setelah *hash* dicocokkan ulang**

Dalam bahasa *incident response* militer, tahap Bertindak setara dengan siklus ***detect* → *contain* → *eradicate* → *recover***, ditutup ***After-Action Review* (AAR)**. Nusantara Shield menegakkan tiga prinsipnya: kontainmen tanpa mematikan fungsi layanan (*mission continuity*), pembersihan tanpa menghapus jejak forensik, dan pemulihan hanya setelah bukti terverifikasi (Purbo dan Lumy, 2025).

3.2 Empat Pilar Kemampuan

1. **Penangkalan dini (lapis pertama)**
    - Kabar ancaman dikorelasikan dengan *port* dan sektor aset milik satuan, **termasuk aset OT**: kabar celah protokol industri Modbus langsung menaikkan pengendali genset ke WASPADA.
    - **AI lokal — Mesin Deteksi Anomali (*anomaly detection engine*):** model *Isolation Forest* (scikit-learn) dilatih di *server* satuan dari profil lalu lintas normal, lalu menilai enam ciri lalu lintas tiap aset dalam milidetik. Lalu lintas tidak wajar menambah peluang serangan dan disertai alasan yang bisa dibaca, misalnya "perintah tulis Modbus 10× normal" (*explainability*).
    - **Mesin Deteksi Aturan (*rule-based detection engine*):** menghitung peristiwa mentah (*login* dan koneksi masuk) dengan ambang terbuka: *login* gagal berulang (8 dalam 60 detik), *login* tembus sesudah rentetan gagal (≤ 120 detik), dan pemindaian *port* (15 kombinasi aset:*port* dalam 10 detik). Peringatannya ikut aturan yang sama dengan CTI dan AI: hanya menaikkan WASPADA, dapat diperketat, dan dapat ditutup lewat triase.
    - Satu klik **Perketat** menurunkan peluang serangan sebelum ancaman tiba.
2. **Respons berdoktrin (lapis kedua, bila ancaman tetap tembus)**
    - **Isolasi standar:** bukti diamankan lebih dulu, lalu ≈1,2 detik kemudian jaringan diputus.
    - **Isolasi Darurat (*Emergency Override*):** bila alat forensik gagal, Operator tetap bisa memutus jaringan, tetapi **wajib menulis alasan** (minimal 15 karakter) dan menahan tombol **1,5 detik**.
    - Setiap jalan pintas ditolak *server* (kode **409**).
3. **Akuntabilitas tak terbantahkan**
    - **Buku Rantai Bukti:** sidik jari SHA-256 tiap barang bukti, petugas, waktu, dan lokasi simpan.
    - **Log audit HMAC berantai:** satu catatan diubah, rantai langsung putus dan ketahuan.
    - **LAPSIT otomatis** bernomor (IR-2026-001…) terbit **hanya setelah semua tindakan pemutusan tuntas**, merujuk nomor bukti atau alasan darurat.
    - **Peringatan terbaru** menyebut nama Operator yang mengisolasi dan nomor berita acara bukti yang sebenarnya; KPI **Waktu respons (MTTC)** dan **Insiden sejak posko aktif** dihitung dari kejadian yang tercatat.

4. **Hemat sumber daya jaringan satuan**
    - Satu "dapur" memasak gambaran situasi sekali per detik untuk semua layar.
    - Layar hanya menerima **ralat (delta)**, bukan gambar utuh, sehingga lalu lintas turun hingga **80%**.
    - Cocok untuk jaringan satuan berpita sempit.

3.3 Terlatih Sebelum Insiden: Drill Kesiapan

Perpres 82/2022 memasukkan sektor **kesehatan** dan **pertahanan** sebagai Infrastruktur Informasi Vital (Pasal 4) dan mewajibkan simulasi tanggap Insiden Siber (Pasal 15). **Drill Kesiapan** menjalankan simulasi itu di dasbor yang sama dengan yang dipakai saat insiden sungguhan:

1. Log sintetis satu cerita (akun layanan cadangan dibobol, lalu pencadangan dimatikan) dibaca **Mesin Deteksi Aturan yang sama** dengan log asli. Aturan yang seharusnya menangkap tetapi diam ikut dilaporkan.
2. Insiden latihan dimulai. Operator menanganinya dari Action Center dan menjawab **satu pertanyaan per fase** penanganan insiden (Deteksi, Analisis, Penahanan, Pemulihan).
3. *Server* menghitung **nilai 0–100 dari jejak yang tercatat**, bukan dari pengakuan: ketepatan keputusan 40, bukti sebelum putus 30, kecepatan penahanan (MTTC) 30. Rumusnya terbuka; hasilnya masuk log audit berantai dan LAPSIT sebagai **LATIHAN**.

Dengan begitu, Operator yang bukan ahli siber dilatih urutan tindakan yang benar sebelum insiden, lalu dipandu urutan yang sama saat insiden sungguhan. Rincian dan batasnya: Dokumentasi Teknis §3.5.

Untuk posko yang dijaga 24 jam, panel Beban Jaringan menampilkan **linimasa 60 menit** berlabel "data latihan" beserta **pita anomali AI per aset** (nama aset, lama, dan alasannya). Tampilannya mengikuti tiga lapis yang dianjurkan untuk pusat komando siber: ***strategic heatmap*** (Peta Global dan kotak Postur), ***operational incident board*** (Action Center dan LAPSIT), dan ***tactical endpoint list*** (Topologi Internal dan daftar aset), dengan ***human-in-the-loop*** pada setiap keputusan pemutusan.

---

4. Keunggulan Taktis (Military Value Proposition)

Seluruh keunggulan berikut **sudah berjalan** di purwarupa dan dapat didemonstrasikan.

Prinsip	Penerapan di Nusantara Shield
Human-in-the-loop — komandan memegang keputusan	Tidak ada tindakan pemutusan tanpa Operator menahan tombol. Pemulihan terkunci sampai syaratnya terpenuhi. Pengecualian darurat wajib beralasan tertulis.
Sistem pendukung keputusan, bukan pengganti keputusan	Sengaja **tidak** otonom penuh. Di jaringan vital, respons otomatis penuh membuka tiga risiko: peringatan keliru yang memutus layanan sendiri, respons yang dapat dipancing pihak luar, dan pemutusan tanpa pejabat yang bertanggung jawab. Kecepatan tetap terjaga: isolasi praotorisasi cukup ditahan 0,6 detik, dan pemutusan selesai ≈1,2 detik dengan bukti disegel lebih dulu.
Mode Berdaulat — tanpa ketergantungan pihak luar	Berjalan **luring penuh**: tanpa Content Delivery Network (CDN), fon, atau layanan awan. Cocok untuk **jaringan tertutup** satuan. Data latihan sintetis (RFC 5737).
Doktrin forensik — *chain of custody*	Bukti diamankan **sebelum** isolasi. Berita acara berantai HMAC. Sidik jari SHA-256 **dicocokkan ulang sebelum pemulihan**; bila tidak cocok, pemulihan dikunci.

Prinsip	Penerapan di Nusantara Shield
Kecepatan OODA — bertindak lebih cepat dari lawan	Peringatan dini sebelum serangan; bukti + isolasi ≈1,2 detik dari keputusan
AI tepat guna — deteksi tanpa *signature*	*Isolation Forest* lokal menilai lalu lintas dalam milidetik, menjelaskan alasannya, dan hanya menaikkan status; keputusan memutus tetap di tangan Operator (*human-in-the-loop*). Dikunci 10 uji khusus AI.
Pertanggungjawaban komando	Setiap keputusan (siapa, apa, kapan, alasan) tercatat di dua buku HMAC. LAPSIT terkirim otomatis ke pimpinan.
Pemisahan wewenang	Peran **Pengamat** (melihat) dan **Operator** (bertindak). Akun Operator hanya lewat kode undangan atau dibuat Operator lain.
Posko yang dijaga berlapis	Alat yang memegang tombol isolasi harus paling terlindungi. Kata sandi disimpan dengan PBKDF2-SHA256 (200.000 putaran), sesi memakai token acak yang kedaluwarsa, *login* dibatasi 5 percobaan per menit, kiriman dibatasi 16 KB, dan antarmuka dikunci kebijakan keamanan konten (*Content Security Policy*, CSP). Dikunci uji keamanan; rincian dan batasnya di Dokumentasi Teknis §2.7.
Selaras NIST CSF 2.0	Fitur dipetakan ke enam fungsi *Cybersecurity Framework* (CSF) 2.0 (tabel di bawah). Pemetaan mandiri oleh tim, bukan sertifikasi.
Sinergi IT/OT	Aset rumah sakit (SIMRS) dan aset kendali (**pengendali genset**, Modbus/TCP *port* 502) berada dalam satu inventaris dan satu layar. Kabar ancaman protokol industri langsung dikorelasikan, dan skenario **Sabotase OT** memutus jalur kantor → zona kendali ≈1,2 detik sejak keputusan Operator (bukti diamankan di awal jeda). Dikunci 6 uji khusus OT.
Bahasa satuan	Seluruh label (jabatan penerima laporan, nama satuan) diatur dari **satu kamus istilah**, tanpa mengubah logika

Pemetaan ke NIST *Cybersecurity Framework* (CSF) 2.0. Kerangka ini lazim dipakai untuk menilai kelengkapan program keamanan siber. Keenam fungsinya sudah diisi fitur yang berjalan; rincian per kategori beserta uji yang membuktikannya ada di Dokumentasi Teknis §2.6.

Fungsi CSF 2.0	Sudah berjalan di Nusantara Shield	Masih peta jalan
Govern (tata kelola)	Dua peran dan dua kunci konfirmasi; Nilai Kesiapan Siber A–E untuk Dansat	—
Identify (kenali)	Inventaris aset IT dan OT; korelasi kabar ancaman × aset; peluang serangan per aset	Inventaris dari sistem satuan yang sebenarnya
Protect (lindungi)	Perketat (simulasi pengerasan); kepatuhan pencadangan < 24 jam dan uji pulih; akses posko berlapis	Pengerasan langsung di perangkat nyata
Detect (deteksi)	AI lokal (*Isolation Forest*); aturan deteksi *login* gagal berulang dan pemindaian *port*, dan aturan OT (atas peristiwa sintetis maupun **log asli yang diimpor Operator**); radar anomali; triase peringatan	Sensor nyata; peristiwa identitas dari Active Directory (perubahan hak akses, akun baru)
Respond (tanggapi)	Bukti dulu → isolasi ≈1,2 detik → LAPSIT; isolasi darurat beralasan; MTTC tercatat	Pengiriman LAPSIT berjenjang otomatis ke Sansidam dan Kartika CSIRT; respons bertingkat menurut kritikalitas aset
Recover (pulihkan)	Pemulihan terkunci sampai sidik jari bukti cocok ulang	—



*Siklus OODA Nusantara Shield. Mesin mengamati dan mengorientasikan; **manusia memutuskan**; server bertindak dalam urutan yang dikunci.*

---

5. Kelayakan Penerapan di Lingkungan Satuan



***Mode Berdaulat:** seluruh sistem, data, bukti, dan log berada di dalam jaringan tertutup satuan.*

5.1 Kedaulatan Sistem dan Mode Hybrid/Luring

> **"Berjalan luring penuh" merujuk pada Aplikasi Inti (Nusantara Shield Core v5.4.1)**, yaitu purwarupa yang diserahkan dan didemonstrasikan dalam lomba ini.

- **Tidak membutuhkan awan atau *server* luar untuk beroperasi.** Seluruh pemrosesan berjalan di *server* atau laptop milik satuan (*on-premise*): layanan web, penyimpanan akun dan data (berkas lokal), sidik jari SHA-256 barang bukti, log audit HMAC, tombol isolasi, LAPSIT, dan AI deteksi anomali. Kode *server* tidak memuat satu pun pemanggilan ke alamat luar.
- **Tanpa ketergantungan eksternal di layar.** Antarmuka tidak memanggil skrip CDN, Google Fonts, atau sumber daring apa pun. Bila internet diputus, dasbor dan *playbook* respons insiden tetap berjalan penuh. Bahkan bila kabel LAN dicabut, *server* dan dasbor di laptop yang sama tetap bekerja.
- **Pemasangan tanpa internet sama sekali.** Paket pasang luring berisi kode dan seluruh pustaka, dilengkapi daftar sidik jari SHA-256. Di posko, sidik jari dicocokkan dengan berita acara serah

terima paket; satu berkas saja berbeda, pemasangan dihentikan. Paket dibawa lewat media yang sudah diperiksa, sehingga siap untuk jaringan *air-gapped*.

- **Mode Hybrid (rancangan lanjutan, belum ada di purwarupa).** Satu-satunya data yang direncanakan melintasi batas jaringan adalah **umpan indikator ancaman resmi** (BSSN/MISP). Umpan masuk satu arah lewat gerbang yang dikendalikan satuan, atau diimpor sebagai berkas lewat media yang diperiksa. Aplikasi inti tetap luring. Pada purwarupa, umpan CTI memakai data latihan sintetis.
- **Batas purwarupa.** Pengambilan bukti dan pemutusan jaringan **disimulasikan** atas aset latihan. Yang berjalan nyata: penguncian urutan di *server*, perhitungan sidik jari SHA-256, buku berantai HMAC, LAPSIT, korelasi CTI, dan penilaian AI lokal (atas ciri lalu lintas sintetis).
- **Dua jenis AI, dengan status yang berbeda:**
  - **(a) Mesin Deteksi Anomali — sudah beroperasi penuh di purwarupa.** Model *machine learning* ringan (*Isolation Forest*, scikit-learn) dilatih dan dijalankan 100% luring di *backend*, lalu memberi skor anomali lalu lintas IT dan OT setiap detik. Ini ***local inference***: tidak ada unduhan model, tidak ada pemanggilan Application Programming Interface (API) luar, dan setelah pemasangan tidak butuh internet sama sekali. Karena itu ia siap untuk **penerapan *air-gapped***: paket pustakanya cukup dibawa lewat media yang diperiksa. Ciri lalu lintasnya di purwarupa masih sintetis.
  - **(b) Mesin Asisten Narasi — peta jalan, belum ada di purwarupa.** Model bahasa lokal (*Local LLM*) **Llama 3 8B lewat Ollama** untuk menyusun draf LAPSIT. Rencananya juga *local inference*: model dihitung di *server* satuan, dan untuk satuan *air-gapped* berkas modelnya diunduh sekali lalu dibawa lewat media yang diperiksa. Model berat ini sengaja **tidak** dimasukkan ke *server* inti agar beban CPU tetap hemat.
  - Dalam kedua jenis, AI hanya menyarankan dan menaikkan status; memutus jaringan tetap keputusan Operator.
- **AI sebagai alat pengembang.** Selain itu, asisten AI dipakai untuk membantu menulis kode dan dokumentasi, sebagaimana diizinkan panitia (lihat 6.2).

5.2 Kesiapan Penerapan

- **Ringan:** satu laptop atau *server* kecil; satu proses Python. Untuk 300 layar serentak, CPU *server* ≈1,5% saat siaga dan ≈1,7% saat serangan, dengan memori ≈207 MB termasuk pustaka AI (scikit-learn dan numpy), jauh di bawah 512 MB; diukur ulang 26 Okt 2026 dengan `tools/ukur_beban.py` (Linux 2 inti, 300 siaran SSE sungguhan). AI menambah kerja *server* hanya ≈0,05 milidetik per detik karena model baru dijalankan saat keadaan lalu lintas berubah.
- **Teruji:** 425 uji otomatis mengunci setiap aturan, termasuk ambang deteksi yang tertulis di dokumen ini, dan dapat dijalankan ulang oleh siapa pun dalam kurang dari satu menit (≈30 detik di Mac, ≈50 detik di Linux ruang kerja awan).
- **Cakupan OT saat ini:** purwarupa memantau **pengendali genset rumah sakit** (Modbus/TCP, *port* 502) di **zona kendali** topologi. Kabar ancaman Modbus menaikkannya ke **WASPADA (≈66%)** sebelum ada serangan. Pada skenario **Sabotase OT**, bukti diamankan, lalu jalur kantor → zona kendali diputus lewat *webhook* (simulasi) ke sakelar terkelola ≈1,2 detik kemudian; genset tetap menyala dengan kendali lokal. Pemulihan jalur kendali terkunci sampai sidik jari bukti cocok.
- **Langkah lanjutan** (semuanya sumber terbuka dan dapat berjalan *air-gapped* atau *on-premise*):
  - telemetri nyata dari sensor dan SIEM satuan (Wazuh, Suricata, Zeek) serta sensor protokol industri Modbus/DNP3;
  - sambungan *webhook* terautentikasi ke sakelar terkelola sungguhan;

- pertukaran CTI dengan Badan Siber dan Sandi Negara (BSSN) dan Kartika Computer Security Incident Response Team (CSIRT) lewat Malware Information Sharing Platform (MISP) atau OpenCTI (STIX/TAXII), menggantikan rancangan Mode Hybrid;
- peristiwa identitas nyata (*login*, perubahan hak akses, akun baru di luar jam kerja) dari Active Directory atau SIEM satuan. Aturan *login* gagal berulang dan *login* tembus sudah berjalan, tetapi baru atas peristiwa sintetis;
- **respons bertingkat menurut kritikalitas aset**: aset vital (SIMRS, pengendali genset, *server* inti) tetap memakai dua kunci; *endpoint* kantor berisiko rendah dapat diisolasi otomatis berdasarkan *playbook* praotorisasi yang ditetapkan Kasi Siber, tetap dengan bukti diamankan lebih dulu dan tercatat di LAPSIT;
- saat tersambung ke perangkat nyata: brankas kredensial, hak minimum per *playbook*, *playbook* bertanda tangan digital, dan persetujuan dua orang untuk mengubah *playbook*;
- akuisisi bukti nyata (misalnya Velociraptor), dan penerusan kasus ke *case management* (TheHive) beserta label MITRE ATT&CK yang sudah ada;
- AI: ciri lalu lintas nyata dari sensor satuan untuk Mesin Deteksi Anomali, dan Mesin Asisten Narasi (Llama 3 8B lewat Ollama) untuk draf LAPSIT, dengan *human-in-the-loop*;
- paket pemasangan luring siap pakai, SSO instansi dengan verifikasi dua langkah, dan operasi multiproses.

5.3 Konsep Penempatan dan Pengguna (Usulan)

Nusantara Shield dirancang dipasang **di posko siber atau *Security Operations Center* (SOC) setiap satuan yang memiliki aset vital**, dengan satu *server* luring per satuan, dan dioperasikan oleh unsur siber yang sudah ada dalam struktur Tentara Nasional Indonesia Angkatan Darat (TNI AD). Dalam kerangka tiga lapis komando siber (strategis, operasional, dan taktis; Purbo dan Lumy, 2025), Nusantara Shield adalah alat **lapis taktis**, yaitu *Cyber Defense Operation Center* (CDOC) di tingkat satuan. Konsep ini disusun dari struktur yang disampaikan secara resmi dan **belum diuji di lingkungan TNI AD**.

Tingkat	Unsur	Peran terhadap Nusantara Shield
Satuan (rumah sakit TNI AD; lapis taktis)	Operator jaga (petugas TI rumah sakit atau Bintara Siber), Kasi Siber, Komandan Satuan (Dansat)	Operator memantau dan menahan tombol isolasi; Kasi Siber menetapkan *playbook* praotorisasi; Dansat menerima LAPSIT sebagai Pengamat.
Komando Daerah Militer (Kodam)	Sandi dan Siber Kodam (Sansidam), melalui Tim Penangkalan Siber	Pendamping dan cadangan Operator; meneruskan laporan ke pusat.
Pusat (lapis operasional)	Satuan pelaksana penangkalan Pussiberad dan Kartika CSIRT	Menerima LAPSIT dan berita acara bukti; menganalisis bukti; menyebarkan kabar ancaman ke satuan.

- **SOC dan ruang komando:** SOC memakai seluruh dasbor setiap hari. Saat krisis, ruang komando cukup menampilkan Executive Overview, Peta Global, dan LAPSIT dengan akun Pengamat.
- **Kebutuhan minimum per satuan:** satu laptop atau PC (2 inti, 512 MB memori bebas), jaringan internal, minimal dua akun Operator dan satu akun Pengamat.
- **Batas peran:** Nusantara Shield hanya untuk jaringan dan aset milik TNI AD. Insiden pada instansi sipil, BUMN, atau pemerintah daerah ditangani BSSN, Komdigi, dan Polri; TNI baru turun bila yang diserang aset militer atau ancamannya sudah setingkat pertahanan negara. Kasus PDNS 2024 dipakai sebagai **pelajaran** tentang tanda bahaya yang terlambat ditindak, bukan sebagai wilayah tugas sistem ini.

5.4 Status Fitur: Sudah Berjalan dan Peta Jalan

Pembedaan ini sengaja dibuat tegas agar juri dapat menilai apa yang benar-benar didemonstrasikan.

Sudah berjalan di purwarupa v5.4.1	**Belum dibangun (peta jalan: Mode Hybrid dan eskalasi)**
Operasi luring penuh di satu satuan/rumah sakit (*on-premise*)	**(1) Pengiriman LAPSIT otomatis berjenjang** ke Sandi dan Siber Kodam (Sansidam) dan Kartika CSIRT (Pussiberad)
Dua peran: Pengamat dan Operator	**(2) Akses dan tampilan lintas satuan** untuk pemantauan serentak di Mabes
Isolasi dengan tombol yang ditahan 0,6 detik	Mesin Asisten Narasi: LLM lokal Llama 3 8B lewat Ollama untuk draf LAPSIT
Rantai bukti HMAC-SHA256	Umpan indikator resmi (BSSN/MISP) lewat gerbang satu arah
Korelasi CTI dan Mesin Deteksi Anomali (*Isolation Forest*, luring)	Aliran langsung dari sensor (Wazuh, Suricata, Zeek; kini lewat impor berkas keluarannya) dan sakelar terkelola sungguhan
Simulasi OT genset (Modbus, *port* 502)	Peristiwa identitas nyata dari Active Directory (perubahan hak akses, akun baru)
Pembuatan LAPSIT dan ekspor PDF	Pengamanan integrasi nyata: brankas kredensial, hak minimum per *playbook*, *playbook* bertanda tangan
Paket pasang luring bersidik jari SHA-256 (tanpa internet sama sekali)	**Respons bertingkat menurut kritikalitas aset:** aset vital tetap dua kunci; *endpoint* kantor berisiko rendah diisolasi otomatis dengan praotorisasi
Mesin Deteksi Aturan: *login* gagal berulang, *login* tembus, pemindaian *port*, koneksi IT ke zona kendali OT tanpa izin, dan perintah tulis Modbus di luar jendela pemeliharaan (ambang terbuka; atas peristiwa sintetis)	
Impor log luring (auth.log OpenSSH, log firewall UFW/iptables, CSV, serta keluaran sensor **Wazuh `alerts.json`** dan **Suricata `eve.json`**; maks. ≈2 MB) dinilai Mesin Deteksi Aturan yang sama; temuan berlabel sumber berkasnya	
Label teknik MITRE ATT&CK (termasuk ATT&CK for ICS) di peringatan, log, dan LAPSIT; label sumber data di setiap peringatan; pengesahan dua tanda tangan di LAPSIT PDF	
Linimasa 60 menit (data latihan), pita anomali AI per aset, KPI Waktu respons (MTTC) dan Insiden sejak posko aktif	
Nilai Kesiapan Siber A–E (dua sub-skor: Kerawanan dan Insiden) dan triase peringatan: Selesai ditangani atau Positif Palsu (*False Positive*), beralasan dan tercatat di Buku Rantai Bukti	
Drill Kesiapan untuk Operator: log sintetis lewat aturan deteksi yang sama, pertanyaan per fase penanganan insiden, nilai 0–100 dari jejak tercatat (dua skenario: cadangan dilepas lewat auth.log; perintah asing ke genset lewat Suricata `eve.json`)	***Tabletop exercise* untuk pimpinan** (Dansat, Kepala RS): *inject* bertahap, doktrin sebagai rubrik; skenario drill lain (*phishing*, perubahan halaman situs satuan)

5.5 Peta Jalan Penguatan dari Studi Banding Arsitektur

Pada 30 Oktober 2026, keempat pilar Nusantara Shield dibandingkan dengan proyek sumber terbuka dan makalah yang relevan. Hasilnya empat penguatan berikut. Yang pertama **sudah dibangun di v5.4.0**; tiga lainnya **belum dibangun**:

Gagasan	Pilar	Masalah yang dijawab	Rujukan studi banding
Evolusi kunci audit dan titik periksa bertanda tangan Ed25519 (**sudah dibangun, v5.3.0**: titik periksa Ed25519 dengan kunci berevolusi; kunci HMAC sendiri belum berevolusi)	Integritas bukti	HMAC memakai satu kunci rahasia untuk membuat sekaligus memeriksa. Bila *server* dibobol, penyerang yang memegang `NS_AUDIT_KEY` bisa menulis ulang riwayat dengan sidik jari yang sah. Kunci yang berevolusi per periode (kunci lama dihapus) membuat catatan masa lalu tidak bisa dipalsukan (*forward security*); titik periksa Ed25519 berkala memungkinkan auditor memeriksa hanya dengan kunci publik	Makalah Nitro (ACM CCS 2025); Trillian dan immudb (log terverifikasi)
Batas waktu *fail-safe* dan aturan dua orang untuk tindakan pemutus	Doktrin Dua Kunci	Setiap tindakan pemutus menjadi Permintaan Otorisasi bernomor yang terikat ke SHA-256 bukti. Kedaluwarsa berarti **tidak dieksekusi** dan tercatat sebagai KEDALUWARSA; untuk aset vital, penyetuju harus akun yang berbeda dari pengusul	StackStorm *Inquiries* (validasi jawaban, TTL); Shuffle (pemicu *User Input* dengan pilihan lanjutkan/batalkan)
Garis dasar Modbus	Konvergensi IT/OT	Peristiwa OT dinormalkan ke format pesan bersama berbasis aktivitas (tanya, jawab, **perintah**), sehingga aturan berlaku lintas protokol (Modbus kini, DNP3 kelak). Pola *polling* dipelajari per pasangan sumber–unit dengan rerata dan simpangan yang diperbarui per peristiwa (algoritma Welford), lalu jeda yang terlalu pendek (skor-Z tinggi) menaikkan WASPADA; ditambah peta rentang register yang sah. Garis dasar baru berlaku setelah **disahkan Operator**	IPAL (RAID 2022); *ics-anomaly-detection* (profil frekuensi *polling*)
Paket intelijen bertanda tangan	Luring	Indikator CTI dan ambang aturan dikirim sebagai berkas terpisah yang diverifikasi kunci rilis yang sama (Ed25519) sebelum diimpor, sehingga intelijen bisa diperbarui lewat media yang diperiksa tanpa internet	Security Onion (pembaruan aturan lewat ISO pada mode *air-gap*)

Semua gagasan di atas ditulis dari nol; yang diambil dari proyek rujukan hanya konsepnya. Titik periksa Ed25519 dibangun lebih dulu (v5.4.0, Dokumentasi Teknis §2.7.1), karena menutup kelemahan nyata pada pilar integritas bukti; tiga gagasan lainnya belum dibangun.

5.6 Peta Jalan dari Tinjauan Independen (10 November 2026)

Pada 10 November 2026, purwarupa ditinjau ulang dari sudut pandang Dewan Juri. Celah yang bisa ditambal langsung ditambal di v5.4.1 (Dokumentasi Teknis §2.7, "Batas yang perlu diketahui"). Gagasan berikut **belum dibangun** dan dicatat sebagai langkah berikutnya, semuanya defensif dan luring:

Gagasan	Masalah yang dijawab
Buka insiden dari temuan	Temuan dari log asli (Wazuh, Suricata, auth.log) kini menaikkan WASPADA, tetapi insiden, bukti, dan isolasi masih lewat jalur latihan. Satu tombol akan membuka insiden langsung dari temuan itu, dengan doktrin Dua Kunci yang sama.

Gagasan	Masalah yang dijawab
Saksi berjenjang luring	Sidik jari log dan nomor titik periksa dicetak di LAPSIT, lalu disimpan satuan atasan. Penggulungan mundur riwayat di posko tetap tertangkap walau penyerang menguasai *server*.
Akun umpan	Akun yang tidak pernah dipakai siapa pun. Setiap upaya *login* ke akun itu adalah tanda pasti ada yang menjelajah, dengan alarm keliru mendekati nol.
Aturan dua orang di *server*	Tindakan pemutus aset vital disetujui dua Operator berbeda dan dijaga *server*, bukan hanya tahan tombol di peramban (lihat juga §5.5).
Paket intelijen bertanda tangan	Pembaruan indikator dan ambang aturan lewat media fisik yang diverifikasi Ed25519 (lihat §5.5).
Peta kesiapan lintas satuan	Nilai Kesiapan Siber dan hasil Drill tiap satuan dihimpun berkala lewat berkas bertanda tangan, sehingga pimpinan melihat satuan mana yang perlu latihan ulang.
Pengelolaan akun	Menonaktifkan akun dan mencabut sesi akun lain dari dasbor; kini akun hanya bisa dibuat dan diganti sandinya.

---

6. Deklarasi Karya dan Atribusi

6.1 Riwayat Pengembangan

Sesuai Rulebook Kartika Cyber Hackathon 2026 bagian G (Ketentuan Karya), tim menyatakan bahwa seluruh kode Nusantara Shield **dikembangkan sejak 15 Oktober 2026**, setelah publikasi program (12 Oktober 2026), mulai dari versi 1 hingga versi 5.1 yang diserahkan. Selain pustaka sumber terbuka yang tercantum pada 6.2, tidak ada kode dari karya pihak lain atau karya tim yang dibuat sebelum tanggal tersebut.

6.2 Atribusi Pustaka dan Alat

Sesuai Rulebook bagian G (Ketentuan Karya), berikut pustaka dan alat pihak ketiga yang digunakan:

Komponen	Kegunaan	Lisensi
FastAPI (beserta Starlette dan Pydantic)	Kerangka *server* dan validasi masukan	MIT dan BSD-3-Clause
Uvicorn	*Server* web asinkron	BSD-3-Clause
ReportLab	Ekspor LAPSIT ke PDF	BSD
pytest dan **HTTPX**	Uji otomatis	MIT dan BSD-3-Clause
Mermaid dan **Playwright (Chromium)**	Hanya untuk menggambar diagram dan mencetak dokumen ini; tidak dipakai aplikasi	MIT, Apache-2.0, dan BSD-3-Clause
scikit-learn dan **NumPy**	Mesin Deteksi Anomali (*Isolation Forest*), berjalan lokal	BSD-3-Clause
Lucide (v0.460.0)	Ikon pada poster, disematkan sebagai SVG sebaris; tidak dipakai aplikasi	ISC
Claude (Anthropic)	Asisten AI untuk membantu menulis kode dan dokumentasi; tidak dipanggil oleh aplikasi	Layanan komersial
MITRE ATT&CK® (Enterprise dan ICS)	Label teknik pada peringatan dan LAPSIT; tabel statis di `app/mitre.py`, pemetaan oleh tim sendiri	Merek dagang The MITRE Corporation; dipakai sebagai rujukan

Komponen	Kegunaan	Lisensi
Gemini (Google)	Eksplorasi awal konsep logo; logo final digambar ulang tim sebagai vektor SVG dan tidak memuat gambar hasil AI	Layanan komersial
Inter dan **JetBrains Mono**	Huruf pada logo horizontal dan spanduk README	SIL Open Font License 1.1
Blok alamat Internet Protocol (IP) Request for Comments (RFC) 5737	Data latihan sintetis	Standar terbuka IETF

6.3 Lisensi

Kode Nusantara Shield dilisensikan di bawah **GNU General Public License v3.0** (`GPL-3.0-only`, berkas `LICENSE`), Copyright (c) 2026 Nusantara Shield Team. Hak cipta tetap milik tim; turunan yang disebarkan wajib tetap berlisensi GPLv3 dan mencantumkan hak cipta tim. Lisensi ini sejalan dengan Rulebook bagian N: Penyelenggara tetap mendapat lisensi non-eksklusif untuk menampilkan dan mempromosikan karya, dan Pussiberad dapat mengadopsi pendekatannya untuk pertahanan siber.

6.4 Rujukan Kerangka

- Purbo, O. W., dan Lumy, G. D. (2025). *Cyber Warfare & Pertahanan Siber Indonesia*. Kerangka OODA, tiga lapis komando siber, *incident response* militer, dan *After-Action Review*.
- Peraturan Presiden Nomor 82 Tahun 2022 tentang Pelindungan Infrastruktur Informasi Vital: Pasal 4 (sektor kesehatan dan pertahanan) dan Pasal 15 (simulasi tanggap Insiden Siber), dasar Drill Kesiapan.
- Satuan Siber TNI. *Visi dan Misi*. satsiber-tni.mil.id/visi-dan-misi-20181230531, diakses 9 November 2026.
- National Institute of Standards and Technology (NIST) SP 800–61, panduan penanganan insiden keamanan komputer: fase deteksi dan analisis serta penahanan, pembersihan, dan pemulihan dipakai sebagai susunan pertanyaan Drill Kesiapan.
- National Institute of Standards and Technology (NIST) SP 800–82, panduan keamanan sistem kendali industri (OT).
- International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) 27037:2012, pedoman identifikasi, pengumpulan, akuisisi, dan pelestarian bukti digital. Alur "bukti dulu, baru putus" dan buku berantai HMAC disusun **mengikuti prinsipnya**; purwarupa belum diaudit terhadap standar ini.
- Wolsing, K., Wagner, E., Saillard, A., dan Henze, M. (2022). *IPAL: Breaking up Silos of Protocol-dependent and Domain-specific Industrial Intrusion Detection Systems*. RAID 2022. Rujukan format pesan OT lintas protokol (§5.5, peta jalan).
- Zhao, R., Shoaib, M., Hoang, V. T., dan Hassan, W. U. (2025). *Rethinking Tamper-Evident Logging: A High-Performance, Co-Designed Auditing System* (Nitro). ACM CCS 2025. Rujukan *forward security* untuk log audit (§5.5, peta jalan).
- National Institute of Standards and Technology (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). Enam fungsi dan kategorinya dipakai untuk **memetakan** fitur (Dokumentasi Teknis §2.6); pemetaan dilakukan tim sendiri, bukan sertifikasi.

---

7. Peta Kriteria Penilaian dan Asal Angka

Bagian ini memudahkan Dewan Juri memeriksa klaim kami sendiri: setiap kriteria Rulebook (bagian H) dipetakan ke bukti di karya, dan setiap angka di dokumen, slide, dan poster ditautkan ke sumbernya.

7.1 Peta Kriteria Penilaian

Kriteria (bobot)	Bukti di Nusantara Shield	Cara memeriksa
Relevansi dan Manfaat (25%)	Menjaga aset IT dan OT rumah sakit TNI AD dalam satu layar; alat lapis taktis (CDOC satuan) dengan LAPSIT untuk Dansat; usulan alur laporan ke Sansidam dan Kartika CSIRT (§5.3); label satuan diatur dari satu kamus istilah	§2 dan §5.3 dokumen ini; Dokumentasi Teknis §3 (SOP respons insiden)
Inovasi Teknis (25%)	"Bukti dulu, baru putus" dikunci *server* (isolasi tanpa bukti ditolak 409); rantai HMAC-SHA256 untuk log audit dan Buku Rantai Bukti; dua kunci (mesin hanya menaikkan WASPADA, manusia memutus); AI *Isolation Forest* luring yang menjelaskan alasannya; korelasi kabar ancaman × aset sebelum serangan; aturan OT deterministik (jalur IT ke OT tanpa izin, perintah tulis Modbus di luar jendela pemeliharaan) yang hanya menaikkan WASPADA; label MITRE ATT&CK; isolasi OT dengan memutus **jalur**, bukan mematikan genset; siaran ralat (*delta*) yang menekan beban *server*	Uji `test_rantai_bukti` (36), `test_ai` (10), `test_ot` (6), `test_deteksi` (24), `test_ot_mitre_lapsit` (23); Dokumentasi Teknis §2.3–2.8
Fungsionalitas Purwarupa (25%)	Aplikasi berjalan penuh dari satu perintah; 4 skenario latihan dan latihan deteksi di dasbor; **impor log asli** (auth.log OpenSSH, log firewall, CSV) dinilai aturan yang sama; **Drill Kesiapan** bernilai untuk Operator; 425 uji otomatis lulus; paket luring dipasang dan diuji tanpa internet di Mac dan di Ubuntu 24.04 (paket bertanda tangan). **Batas yang kami akui:** telemetri langsung dan kabar ancaman masih sintetis (log asli baru masuk lewat impor berkas, belum sensor terus-menerus), dan perintah ke sakelar jaringan masih simulasi	`./run_tests.sh`; halaman rilis v5.1.2 beserta sidik jari paket; video demo
Kelayakan Implementasi (15%)	Satu proses Python di laptop atau *server* kecil; ≈1,5% CPU untuk 300 layar; berjalan dan dipasang tanpa internet dengan sidik jari SHA-256, dan untuk Ubuntu 24.04 dengan paket bertanda tangan Ed25519 serta layanan systemd yang dikeraskan; peran Operator dan Pengamat; peta jalan ke sensor sumber terbuka (Wazuh, Suricata, Zeek) dan MISP	§5 dokumen ini; Dokumentasi Teknis §4.4 (pemasangan luring)
Kualitas Dokumentasi (10%)	Proposal ini, Dokumentasi Teknis, Panduan Belajar (PDF), dek presentasi, poster A4, README, CHANGELOG per perubahan, dan deklarasi serta atribusi (§6)	Folder `docs/` dan `presentation/` di repositori

7.2 Asal Setiap Angka

Angka	Artinya	Sumber	Catatan
≈66% → ≈20%	Peluang serangan pengendali genset setelah kabar celah Modbus, sebelum dan sesudah Perketat	Rumus korelasi di `app/telemetri.py` (0,80 × 0,75 × 1,1 ≈ 66%); dikunci `test_ot` (60–70%, lalu di bawah 30%)	Kabar ancaman dan bobotnya data latihan sintetis
≈1,2 detik	**Satu definisi untuk semua dokumen:** dari Operator selesai menahan tombol sampai jalur pertama diputus. Bukti diamankan di awal jeda itu	Konstanta `JEDA_RUNBOOK = 1.2` di `app/telemetri.py`; urutannya dikunci `test_ot` dan `test_rantai_bukti`	Waktu alur di purwarupa. Pengambilan bukti tersimulasi (seketika) dan pemutusan ke sakelar masih simulasi. Di produksi, total waktu = lama pengambilan bukti + 1,2 detik (Dokumentasi Teknis §3.2)
0,6 detik	Lama tombol isolasi harus ditahan Operator	`static/app.js` (tahan 600 ms)	Mencegah klik tak sengaja
8 kali / 60 detik, **≤120 detik**, **15 kombinasi / 10 detik**	Ambang *login* gagal berulang, *login* tembus, dan pemindaian *port*	`app/deteksi.py`; dikunci `test_deteksi::test_ambang_terbuka_sesuai_dokumentasi`	Dihitung atas peristiwa sintetis
22.00–02.00, **600 detik**	Jendela pemeliharaan perintah tulis Modbus, dan jendela rantai IT → OT	`app/deteksi.py`; dikunci `test_ot_mitre_lapsit` (jendela diuji per jam)	Jam pada peristiwa Modbus juga sintetis
≈1,5% siaga · ≈1,7% serangan, **≈207 MB**, **0,28–0,40 MB/s**	CPU, memori, dan lalu lintas *server* untuk 300 layar	`tools/ukur_beban.py`, 26 Okt 2026, Linux 2 inti, 300 siaran SSE sungguhan; Dokumentasi Teknis §2.3	Bisa diulang siapa pun dengan alat yang sama

Angka	Artinya	Sumber	Catatan
−80% (8,4 → 1,7 MB/s)	Efek optimasi siaran ralat	Uji beban 15–17 Okt 2026; Dokumentasi Teknis §2.3	Riwayat optimasi dengan mesin dan alat ukur awal yang tidak disertakan di repositori; tidak dibandingkan langsung dengan angka versi akhir
≈10 milidetik	Waktu AI menilai 9 aset	`skor_ms` di `app/ai_anomali.py`; dikunci `test_ai` (di bawah 100 ms)	Ukuran di mesin pengembang; uji sengaja memberi batas longgar
425 uji	Perilaku yang dikunci uji otomatis	`./run_tests.sh`; 425 lulus pada 10 Nov 2026 (Linux ≈50 detik)	Rilis v5.2.0 (334 uji saat itu) juga lulus semua setelah paket Ubuntu 24.04 bertanda tangan dipasang sebagai root dengan jaringan diputus
200.000 putaran, **5 percobaan/menit**, **16 KB**	PBKDF2-SHA256 untuk kata sandi, batas *login*, batas kiriman	`app/keamanan.py`; dikunci `test_keamanan` (`test_tebak_sandi_dibatasi`, uji batas kiriman)	—

Lampiran: Kamus Istilah

Kamus ini untuk pembaca yang tidak berlatar militer atau teknis. Istilah diurutkan menurut abjad.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
Air-gapped	Jaringan terpisah dari internet	Jaringan yang secara fisik tidak tersambung ke internet sama sekali.
Cyber drill	Latihan tanggap insiden	Simulasi insiden dengan skenario khusus satu organisasi; kecepatan dan ketepatan tim dinilai. Di sistem ini: Drill Kesiapan.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
Explainability	Keterjelasan	AI wajib menyebut alasannya dalam bahasa manusia, misalnya "perintah tulis Modbus 10× normal".
False Positive	Positif Palsu	Alarm yang ternyata bukan ancaman. Operator menutupnya dengan alasan tertulis; penutupan tercatat permanen dan tidak menghapus apa pun.
***Hash* / SHA-256**	Sidik jari digital; SHA-256 = *Secure Hash Algorithm 256-bit*	Rumus yang mengubah isi berkas menjadi 64 karakter. Isi berubah satu huruf, sidik jarinya berubah total.
Human-in-the-loop	Manusia tetap memegang keputusan	Mesin hanya menyarankan; tindakan memutus jaringan harus disetujui Operator.
Local inference	Perhitungan AI di komputer sendiri	Model dijalankan di *server* sendiri, bukan lewat layanan di internet. Berbeda dengan *air-gapped*.
Machine learning	Pembelajaran mesin	Komputer belajar pola dari contoh data, bukan dari aturan yang ditulis satu per satu.
On-premise	Terpasang di tempat sendiri	Dipasang di perangkat milik satuan, bukan disewa dari layanan awan.
Playbook	Buku panduan langkah	Urutan tindakan baku untuk setiap jenis insiden.
Port	Pintu layanan	Nomor "pintu" di perangkat; tiap layanan punya nomornya sendiri.
Ransomware	Program penyandera data	Program jahat yang mengunci data lalu meminta tebusan.
Server	Komputer pelayan	Komputer yang melayani komputer lain; di sini tempat Nusantara Shield berjalan.
Tabletop exercise (TTX)	Latihan diskusi skenario	Latihan untuk pimpinan: yang diuji keputusan saat insiden, bukan kemampuan teknis. Masuk peta jalan.
Webhook	Panggilan otomatis	Pesan otomatis dari satu sistem ke sistem lain, misalnya perintah ke sakelar jaringan.
AAR	*After-Action Review* (tinjauan pascatindakan)	Rapat evaluasi setelah insiden: apa yang terjadi, apa penyebabnya, dan apa yang diperbaiki.
Action Center	Pusat tindakan	Panel di dasbor tempat Operator melihat insiden dan menekan tombol isolasi.
AI lokal	Kecerdasan buatan yang berjalan di komputer sendiri	Model yang dilatih dan dihitung di *server* satuan, tanpa mengirim data ke internet.
Alamat IP	Alamat *Internet Protocol*	Nomor unik setiap perangkat di jaringan, seperti nomor rumah.
API	*Application Programming Interface*	"Loket" tempat layar dan *server* saling meminta data.
Aset	Barang yang dilindungi	Perangkat atau sistem penting: komputer, *server*, basis data, genset.
ASGI	*Asynchronous Server Gateway Interface*	Antarmuka standar antara *server* web dan aplikasi Python; di sini gerbang yang menolak kiriman terlalu besar sebelum menyentuh logika.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
ATT&CK	*Adversarial Tactics, Techniques, and Common Knowledge* (MITRE)	Katalog publik taktik dan teknik penyerang; dipakai untuk melabeli peringatan, misalnya T0855.
Bintara Siber	Prajurit TNI AD berpangkat bintara di bidang siber	Calon Operator harian sistem ini di satuan.
BSSN	Badan Siber dan Sandi Negara	Lembaga keamanan siber nasional.
CDN	*Content Delivery Network*	Layanan luar untuk memuat huruf atau skrip situs web. Nusantara Shield tidak memakainya.
CDOC	Cyber Defense Operation Center	Pusat operasi pertahanan siber di tingkat satuan.
CPU	Central Processing Unit	Otak komputer; persentasenya menunjukkan seberapa sibuk *server*.
CSF 2.0	*Cybersecurity Framework* 2.0 (NIST)	Kerangka keamanan siber dengan enam fungsi: *Govern*, *Identify*, *Protect*, *Detect*, *Respond*, dan *Recover*.
CSIRT	*Computer Security Incident Response Team*	Tim tanggap insiden siber. Kartika CSIRT adalah milik TNI AD.
CSP	*Content Security Policy* (kebijakan keamanan konten)	Aturan yang hanya mengizinkan skrip dan gaya milik aplikasi sendiri berjalan di layar.
CTI	*Cyber Threat Intelligence* (intelijen ancaman siber)	Kabar dari luar tentang ancaman yang sedang beredar, misalnya celah baru pada suatu perangkat.
Dansat	Komandan Satuan	Pimpinan unit; di sistem ini berperan sebagai Pengamat yang menerima laporan.
DDoS	*Distributed Denial of Service*	Serangan banjir permintaan agar layanan lumpuh karena kewalahan.
Deteksi anomali	Pengenalan perilaku tidak wajar	Menandai lalu lintas yang menyimpang dari kebiasaan, tanpa perlu daftar serangan yang sudah dikenal.
DMZ	Demilitarized Zone	Zona penyangga antara internet dan jaringan dalam, seperti lobi.
Drill Kesiapan	Latihan tanggap insiden bernilai	Log sintetis satu cerita, satu pertanyaan per fase penanganan, nilai 0–100 dari jejak yang tercatat sistem (§3.3).
Enkripsi	Penyandian data	Mengubah data menjadi sandi. *Ransomware* memakainya untuk mengunci data korban.
Forensik digital	Penyelidikan bukti elektronik	Mengamankan dan memeriksa jejak digital agar pelaku bisa ditelusuri dan bukti sah.
HMAC	*Hash-based Message Authentication Code*	Segel digital berkunci. Setiap catatan log disegel dan terhubung ke catatan sebelumnya, sehingga perubahan diam-diam langsung ketahuan.
HSTS	HTTP Strict Transport Security	Aturan agar peramban selalu memakai sambungan terenkripsi.
HTTPS	Hypertext Transfer Protocol Secure	Sambungan web yang dienkripsi.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
IIV	Infrastruktur Informasi Vital	Sistem elektronik yang gangguannya berdampak serius; menurut Perpres 82/2022 termasuk sektor kesehatan dan pertahanan.
IP	Internet Protocol	Alamat IP: "nomor kamar" setiap perangkat di jaringan.
ISO/IEC 27037	International Organization for Standardization/International Electrotechnical Commission, standar 27037:2012	Pedoman internasional mengidentifikasi, mengumpulkan, mengambil, dan melestarikan bukti digital. Nusantara Shield mengikuti prinsipnya; belum diaudit terhadapnya.
Isolasi	Pemutusan jaringan	Memutus jalur perangkat yang diserang agar serangan tidak menyebar.
Isolation Forest	Nama algoritma *machine learning*	Cara mesin menemukan data yang aneh: data yang tidak wajar paling cepat "terpisah" dari kelompoknya.
IT	*Information Technology* (teknologi informasi)	Komputer kantor, *server*, dan jaringannya.
Kesdam	Kesehatan Daerah Militer	Badan pelaksana kesehatan di tingkat Kodam, membawahi rumah sakit jajaran.
Kesiapan Siber (nilai)	Rapor A–E kesiapan layanan dan posko	Gabungan dua sub-skor 0–100, Kerawanan dan Insiden; yang dipakai adalah yang lebih rendah.
Kodam	Komando Daerah Militer	Komando TNI AD tingkat wilayah (provinsi).
LAPSIT	Laporan Situasi	Laporan resmi singkat tentang insiden: apa, di mana, kapan, dan tindakan yang diambil.
LLM	*Large Language Model* (model bahasa besar)	AI penyusun teks, misalnya Llama 3 8B. Di proyek ini masih rencana.
Log audit	Catatan jejak	Daftar siapa melakukan apa dan kapan di dalam sistem.
Luring	Di luar jaringan (*offline*)	Berjalan tanpa sambungan internet.
Mabes	Markas Besar	Markas pusat, misalnya Mabes TNI atau Mabesad (Markas Besar TNI AD).
MISP	Malware Information Sharing Platform	Platform berbagi kabar ancaman antarlembaga.
ML	Machine Learning	Cara komputer belajar pola dari contoh data.
Modbus	Bahasa komunikasi mesin industri	Protokol untuk memerintah mesin seperti genset; memakai *port* 502.
MTTC	*Mean Time To Contain* (rata-rata waktu penahanan)	Rata-rata waktu dari insiden dimulai sampai ancaman ditahan, misalnya jaringan aset terdampak sudah diputus.
NIST	National Institute of Standards and Technology	Lembaga standar Amerika Serikat; SP 800-82 adalah panduan keamanan sistem industri, dan CSF 2.0 adalah kerangka keamanan siber umumnya.
OODA	*Observe–Orient–Decide–Act*	Siklus keputusan: Amati, Orientasi, Putuskan, Bertindak. Siapa yang lebih cepat, dia unggul.
Operator	Petugas jaga sistem	Satu-satunya peran yang boleh menekan tombol tindakan.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
OSINT	Open Source Intelligence	Intelijen dari sumber terbuka, misalnya berita dan buletin keamanan.
OT	*Operational Technology* (teknologi operasional)	Perangkat yang mengendalikan mesin fisik, seperti genset dan catu daya rumah sakit.
PBKDF2	*Password-Based Key Derivation Function 2*	Cara menyimpan kata sandi dengan hitungan berulang, sehingga sulit ditebak bila berkasnya bocor.
PDNS	Pusat Data Nasional Sementara	Pusat data pemerintah yang lumpuh diserang *ransomware* pada Juni 2024.
Pemindaian *port*	*Port scan*	Satu alamat mencoba banyak "pintu" perangkat dalam waktu singkat untuk mencari layanan yang terbuka; sering menjadi tanda awal serangan.
Perketat	Pengerasan (*hardening*)	Tombol untuk mengurangi celah sebuah aset sebelum diserang.
Perpres	Peraturan Presiden	Perpres 82/2022 mewajibkan simulasi tanggap insiden siber bagi Penyelenggara IIV (Pasal 15).
Purwarupa	*Prototype*	Versi percobaan untuk membuktikan gagasan, belum dipakai di lapangan.
Pussiberad	Pusat Siber Angkatan Darat	Satuan pusat TNI AD yang menangani pertahanan siber; penyelenggara lomba.
RDP	Remote Desktop Protocol	Cara mengendalikan komputer dari jarak jauh.
RFC 5737	Standar alamat IP contoh	Blok alamat IP khusus dokumentasi yang tidak dipakai di internet sungguhan, sehingga aman untuk demo.
RSPAD	Rumah Sakit Pusat Angkatan Darat (Gatot Soebroto)	Rumah sakit rujukan tertinggi TNI AD di Jakarta.
Sansidam	Sandi dan Siber Kodam	Unit sandi dan siber di tingkat Kodam yang membantu satuan di wilayahnya.
Satuan	Unit organisasi militer	Misalnya rumah sakit TNI AD beserta personelnya.
SEV-1	*Severity 1* (tingkat keparahan tertinggi)	Label untuk insiden paling gawat.
SIMRS	Sistem Informasi Manajemen Rumah Sakit	Sistem komputer rekam medis dan layanan pasien.
SOAR	*Security Orchestration, Automation and Response*	Otomasi langkah respons keamanan, misalnya pemutusan jalur yang sudah disetujui.
SOC	*Security Operations Center* (pusat operasi keamanan)	Ruang dan tim yang memantau keamanan jaringan setiap saat.
SPK	Sistem pendukung keputusan	Sistem yang menyiapkan informasi dan pilihan tindakan; keputusan akhir tetap di tangan manusia.
SSE	*Server-Sent Events*	Cara *server* mengirim kabar terbaru ke layar secara langsung.
SSH	Secure Shell	Akses jarak jauh ke *server* lewat baris perintah.
STIX	Structured Threat Information Expression	Format standar untuk menulis kabar ancaman.
TAXII	Trusted Automated Exchange of Intelligence Information	Cara standar mengirim kabar ancaman antarsistem.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
TTIS	Tim Tanggap Insiden Siber	Tim yang menangani insiden siber; di TNI AD, TTIS melayani pemantauan, analisis risiko, penanganan, dan pendampingan pemulihan.
TNI AD	Tentara Nasional Indonesia Angkatan Darat	Matra darat dari angkatan bersenjata Indonesia.
Uji otomatis	*Automated test*	Daftar periksa yang dijalankan komputer untuk memastikan setiap aturan sistem benar.
WASPADA	Status siaga	Tanda kuning: aset berisiko tinggi diserang, walaupun serangan belum terjadi.
Zona kendali	Jaringan khusus mesin (OT)	Bagian jaringan tempat pengendali mesin fisik berada, dipisah dari jaringan kantor.